

Introduction a la Sécurité

Principes de Sécurité

Master 1: SI/SR

Enseignant: Assane Gueye

Juin 24, 2024

Note: Courtesy to the many sources (IAEA, Paxson, Marie,...)

Des attaques partout et tous les jours...

...Il faut donc protéger....

...mais quoi?....

Systemes d'information?

Systemes d'information



Site



Matériel



Reseaux



logiciel



Acteurs



Information

Systèmes d'information

Collections de...

- Hardware!
- **Logiciels (programmes, applications)**
- Outils de stockage
- Données
 - **En « repos »**
 - **En transit**
- Les personnes
- Le(s) réseau(x)
- Le site
- **Actifs critiques d'une banque?**
 - Cash?
 - Or/Argent?
 - Information sur clients?
 - Stocker sur papier, disque
 - En transit: Internet, téléphone, satellite, etc...
 - Dois être protégé a tout moment (Conséquences?)

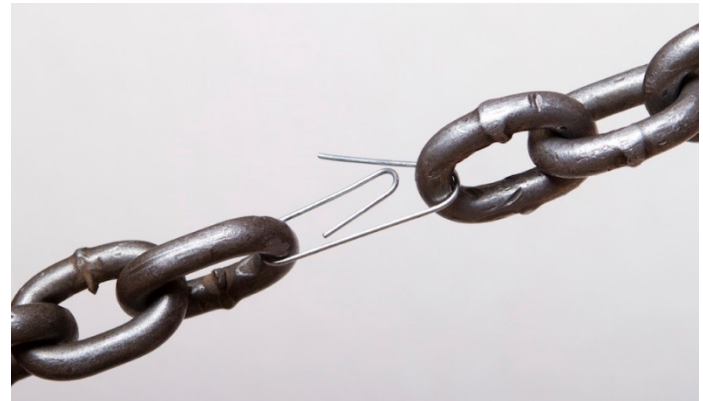
Systèmes d'information

Collections de...

- Hardware!
- Logiciels (programmes, applications)
- Outils de stockage
- Données
 - En « repos »
 - En transit
- Les personnes

Protection

Principe No 1: Maillon Faible



Systemes d'information

Protection

Principe No 1: Maillon Faible

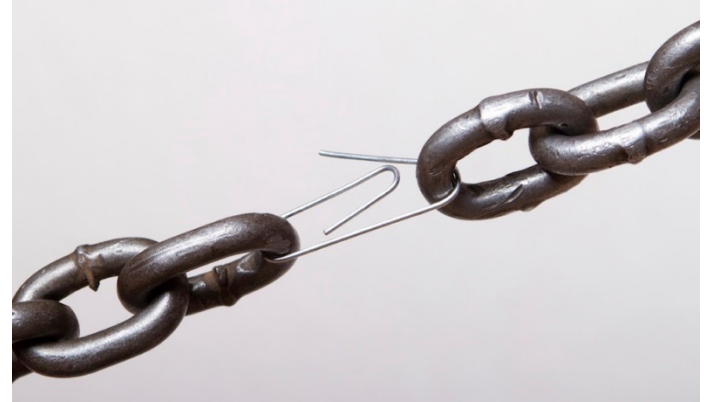


Ou est le maillon faible?

Systemes d'information

Protection

Principe No 1: Maillon Faible

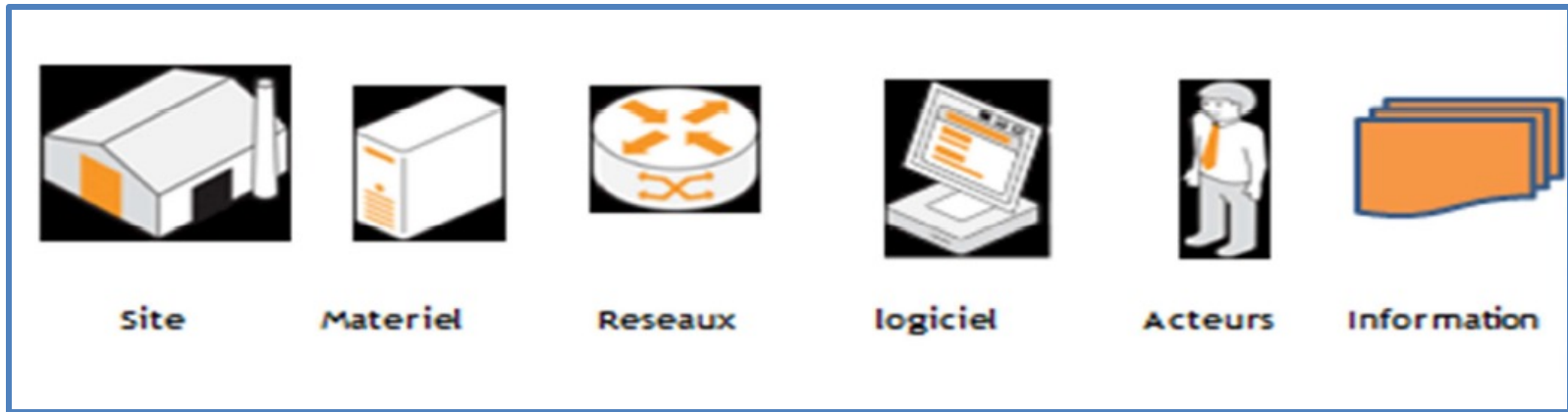


Ou est le maillon faible?

Beaucoup croient que...



Faiblesse/Vulnérabilités



Menaces

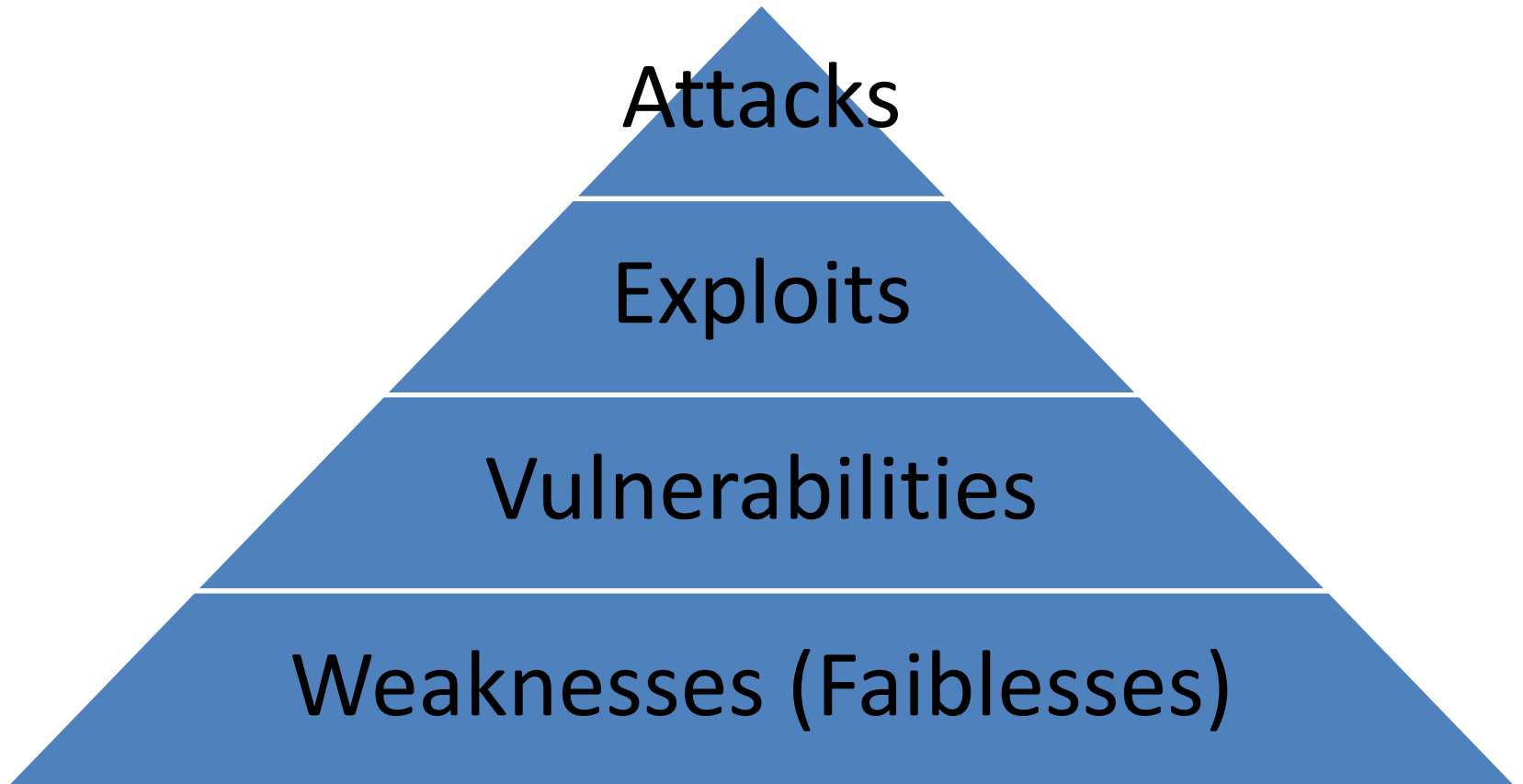


Attaques



Faiblesse / Vulnérabilité ???

Some Jargon!



Vulnérabilité

Vulnérabilité

Faible dans les systèmes d'information (procédure, design, implémentation) qui peut être qui

- Peut être utilisée par une personne malintentionnée pour causer des dégâts.
- Peut engendrer des dégâts de manière accidentelle



Site



Matériel



Reseaux



logiciel



Acteurs



Information



Vulnérabilités

Hardware, Software, Data!

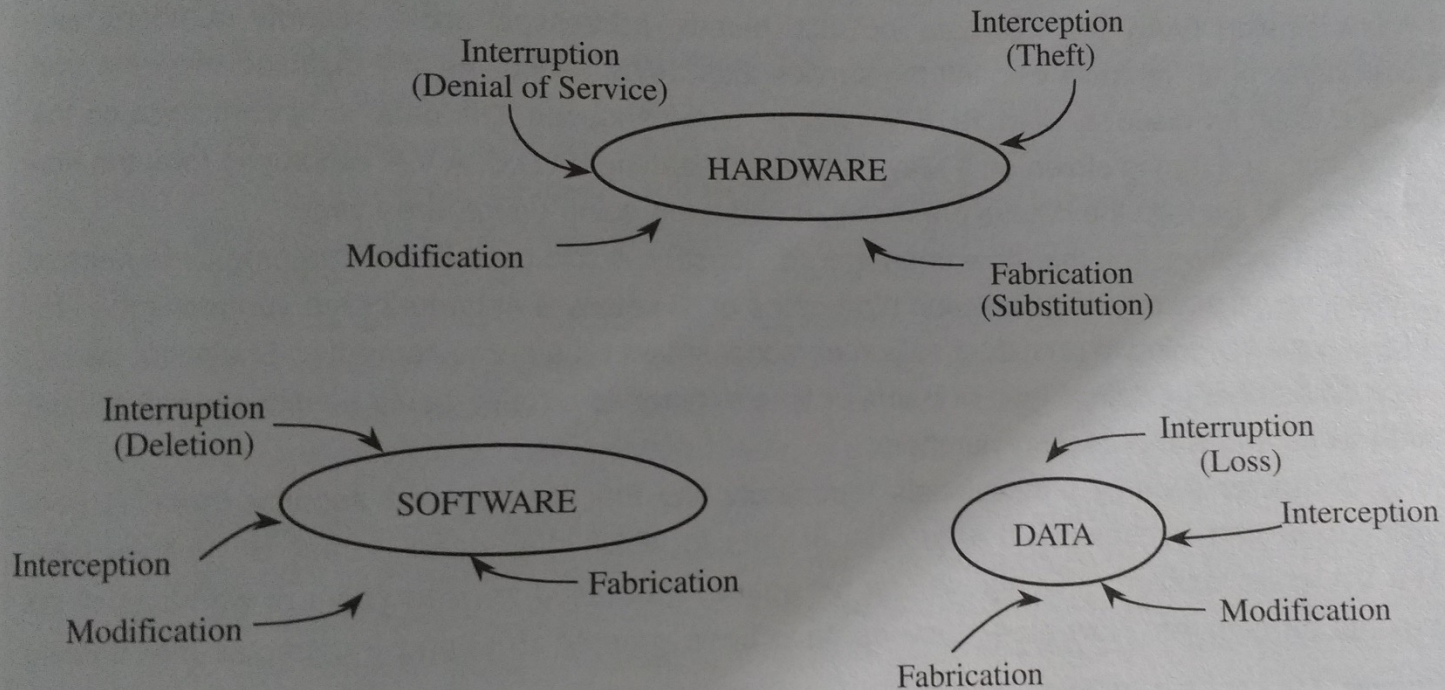
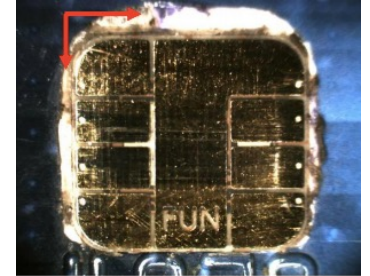


FIGURE 1-4 Vulnerabilities of Computing Systems.

Vulnérabilités du Hardware

- Risques
 - Vols/enlèvement de matériels
 - Echange
 - Ajout des matériels
 - Interception de trafic
- Qlqs attaques sur les machines
 - Verser de l'eau, gazer, geler, électrocuter etc...
 - « Machinicide » (Voluntary Machine Slaughter)
- Protection
 - Physique
 - Encryptions



Vulnérabilités des Applications

Challenges en développement de software

- S'assurer que l'application fait ce qu'elle est supposée faire
- S'assurer que l'application ne fait pas ce qu'elle n'est pas censée faire (bcps plus difficile)

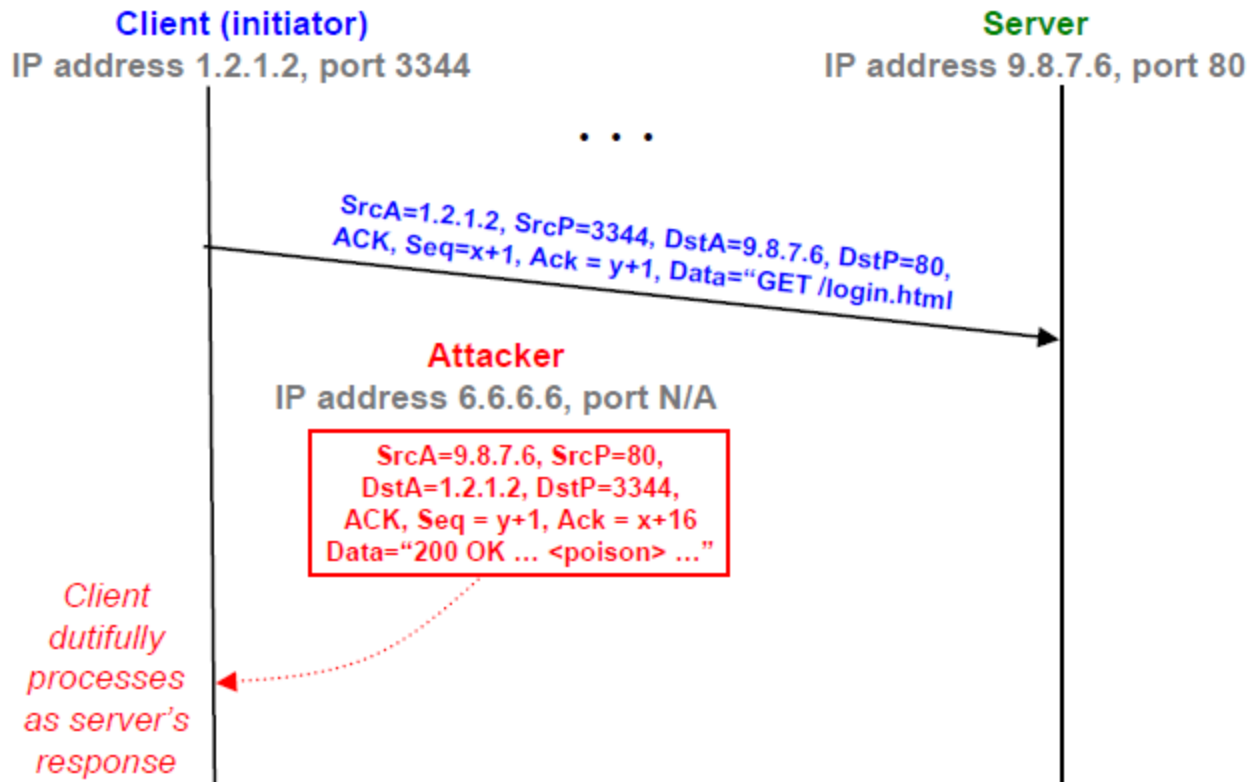
- Risques

- Virus
 - Cheval de Troie
 - Worms
 - Fuite d'information
 - Modification de software (Exemple : employer de banque!)
 - Acces web: XSS
-
- ...Nous allons y revenir

Vulnérabilités des Protocoles

Couche Transport:

Menace TCP: Injection de Données Malicieuses



Vulnérabilités des Acteurs

« Seuls les amateurs attaquent les machines; les professionnelles attaquent les utilisateurs »

Bruce Schneier

Security is too often merely an illusion, an illusion sometimes made even worse when gullibility, naivete, or ignorance come into play. The world's most respected scientist of the twentieth century, Albert Einstein, is quoted as saying, "Only two things are infinite, the universe and human stupidity, and I'm not sure about the former." In the end, social engineering attacks can succeed when people are stupid or, more commonly, simply ignorant about good security practices.

Le saviez-vous?

- Il y'a autant d'attaques qui exploitent la « **psychologie** » que d'attaques qui exploitent la « **technologie** » (ou même plus)!
 - L'hameçonnage est le cyber-crime le plus répandu.
 - **C'est aussi facile!**
 - Les fraudes en ligne...
 - Plus faciles
 - Plus difficile a déjouer et arrêter
- ... il est plus facile pour un criminel de construire une copie truquée du site de la banque que de braquer la banque!

Vulnérabilités du Site

Prévenir l'accès aux locaux



Portes sécurisées

Détection d'intrusion



Gardien



Détruire information sensible



Document papier!

Challenges avec document numérique!

- Copies dans plusieurs mediums (disque, emails, etc...)
- Est-ce que «DELETE» suffit?

Solutions: Réécrire sur le disque, brûler, faire passer dans puissante champ magnétique!

Vulnerabilities Resources

Common Vulnerabilities and Exposures (CVE)

<http://cve.mitre.org/index.html>

Common Vulnerabilities and Exposures (CVE®) is a list of common identifiers for publicly known cybersecurity vulnerabilities.

Each CVE Entry includes the following:

- ♦ CVE ID [number](#) with four or more digits in the sequence number portion of the ID (e.g., "CVE-1999-0067", "CVE-2014-12345", "CVE-2016-7654321").
- ♦ Brief [description](#) of the security vulnerability or exposure.
- ♦ Any pertinent [references](#) (i.e., vulnerability reports and advisories).

Example: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2019-6857>

Vulnerabilities Resources

Common Weaknesses Enumeration (CWE)

<https://cwe.mitre.org/index.html>

Overview - What Is CWE?

Targeted to developers and security practitioners, the Common Weakness Enumeration (CWE) is a formal list of software weakness types created to:

- Serve as a common language for describing software security weaknesses in architecture, design, or code.
- Serve as a standard measuring stick for software security tools targeting these weaknesses.
- Provide a common baseline standard for weakness identification, mitigation, and prevention efforts.

CWE Data: <https://cwe.mitre.org/data/index.html>

Vulnerabilities Resources

National Vulnerability Database (NVD)

<https://nvd.nist.gov/>

The NVD is the U.S. government repository of standards-based vulnerability management data represented using the Security Content Automation Protocol (SCAP). This data enables automation of vulnerability management, security measurement, and compliance.

Example: <https://nvd.nist.gov/vuln/detail/CVE-2018-20650>

Vulnerabilities Resources

Common Vulnerabilities Scoring System (CVSS)

<https://www.first.org/cvss/>

The Common Vulnerability Scoring System (CVSS) provides a way to capture the principal characteristics of a vulnerability and produce a numerical score reflecting its severity. The numerical score can then be translated into a qualitative representation (such as low, medium, high, and critical) to help organizations properly assess and prioritize their vulnerability management processes.

CVSS Calculator: <https://www.first.org/cvss/calculator/3.1>

adopters

CVSS

IPA

Information Technology for the Information Age

IBM

symantec.

hp
invent

ArcSight

(A)
assuria

QUALYS[®]
ON-DEMAND SECURITY



McAfee[®]

skype[™]

skybox[™]
security

BIGFIX

nCircle[®]
Proactive Network Security

secure elements[®]
audit. evaluate. comply.

E-SECURE-IT
ALERT & EARLY WARNING SYSTEM
WWW-SECUREIT.COM

redseal
SYSTEMS

CISCO[®]

SECURITY DATABASE.
KEEP A VIGILANT EYE ON YOUR DEFENSES

Security Risk Management Solutions
netVigilance[®]
assurance has arrived

ORACLE[®]

ThreatGuard

TENABLE[®]
Network Security[®]

NIST

FIRST[™]
Improving Security Together

Slide 6 / CVSS Basics [For Public Release]
© 2007 by FIRST.Org, Inc.

3.2.1 Base Equation

The base equation is the foundation of CVSS scoring. The base equation is:

$$\text{BaseScore}^6 = \text{round_to_1_decimal}(((0.6 * \text{Impact}) + (0.4 * \text{Exploitability}) - 1.5) * f(\text{Impact}))$$

$$\text{Impact} = 10.41 * (1 - (1 - \text{ConfImpact}) * (1 - \text{IntegImpact}) * (1 - \text{AvailImpact}))$$

$$\text{Exploitability} = 20 * \text{AccessVector} * \text{AccessComplexity} * \text{Authentication}$$

$$f(\text{impact}) = 0 \text{ if } \text{Impact} = 0, 1.176 \text{ otherwise}$$

AccessVector = case AccessVector of
requires local access: 0.395
adjacent network accessible: 0.646
network accessible: 1.0

AccessComplexity = case AccessComplexity of
high: 0.35
medium: 0.61
low: 0.71

Authentication = case Authentication of
requires multiple instances of authentication: 0.45
requires single instance of authentication: 0.56
requires no authentication: 0.704

ConfImpact = case ConfidentialityImpact of
none: 0.0
partial: 0.275
complete: 0.660

IntegImpact = case IntegrityImpact of
none: 0.0
partial: 0.275
complete: 0.660

AvailImpact = case AvailabilityImpact of
none: 0.0
partial: 0.275
complete: 0.660

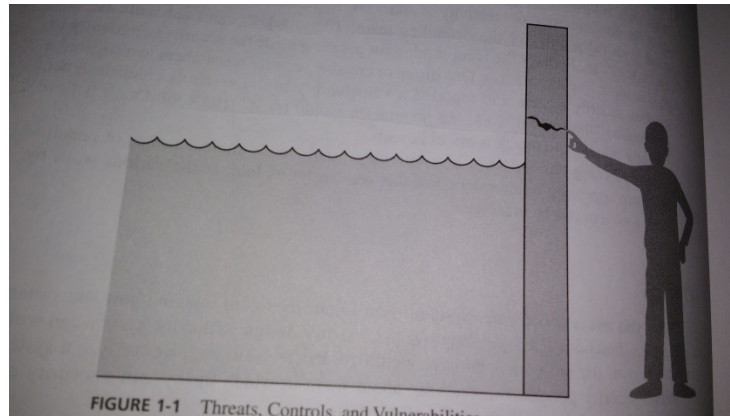
Menace???

Menaces

Menace

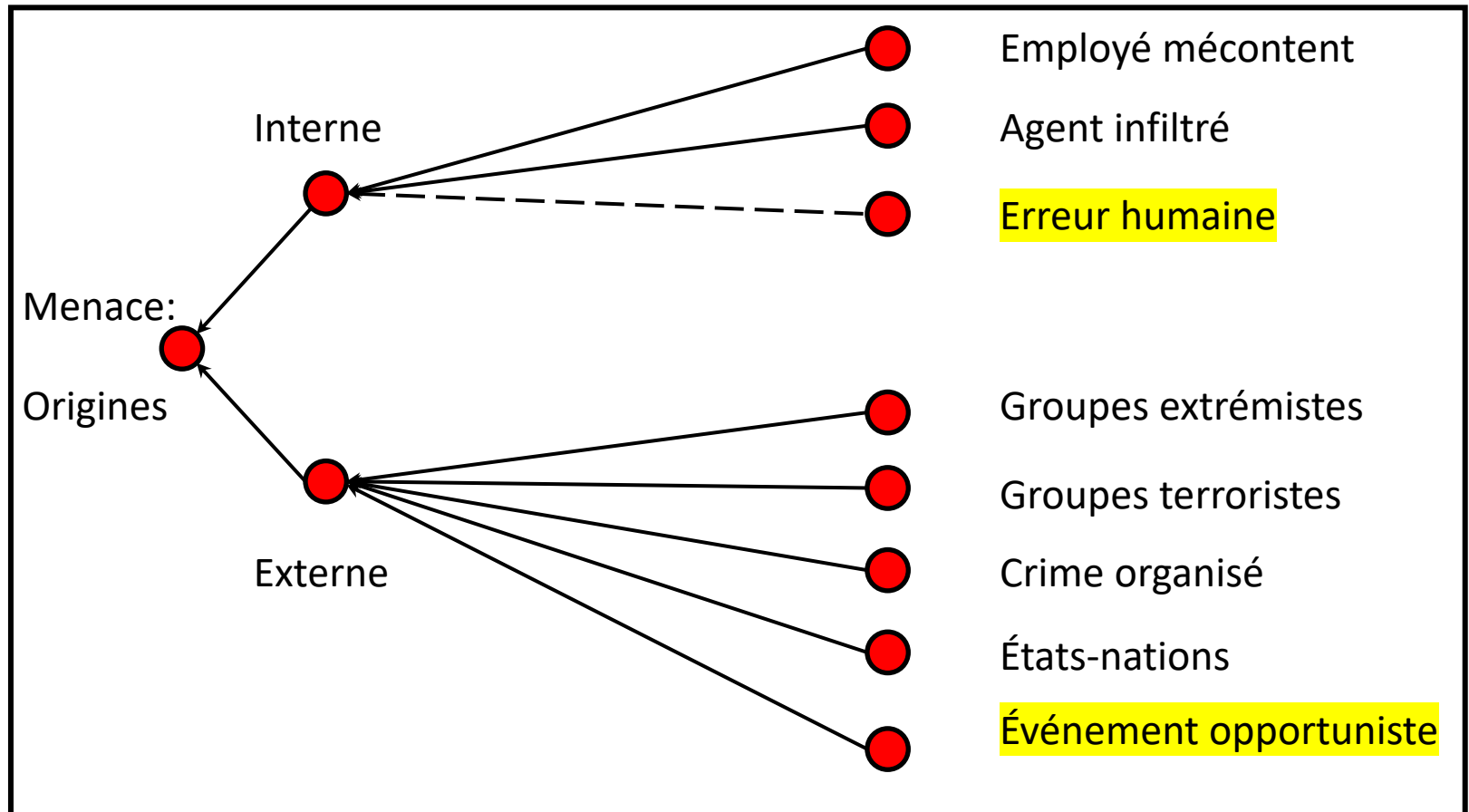
Ensemble de circonstances qui peuvent engendrer les incidents

Menace = intention + capacité + opportunité



Opportunité: (Exemple: faille, vulnérabilité)

Qui sont les auteurs des menaces



...et quels sont leurs moyens, motivations, intentions, etc...????

"If you know the enemy and know yourself, you need not fear the result of a hundred battles. If you know yourself but not the enemy, for every victory gained you will also suffer a defeat. If you know neither the enemy nor yourself, you will succumb in every battle."

- Sun Tzu

change blue to red

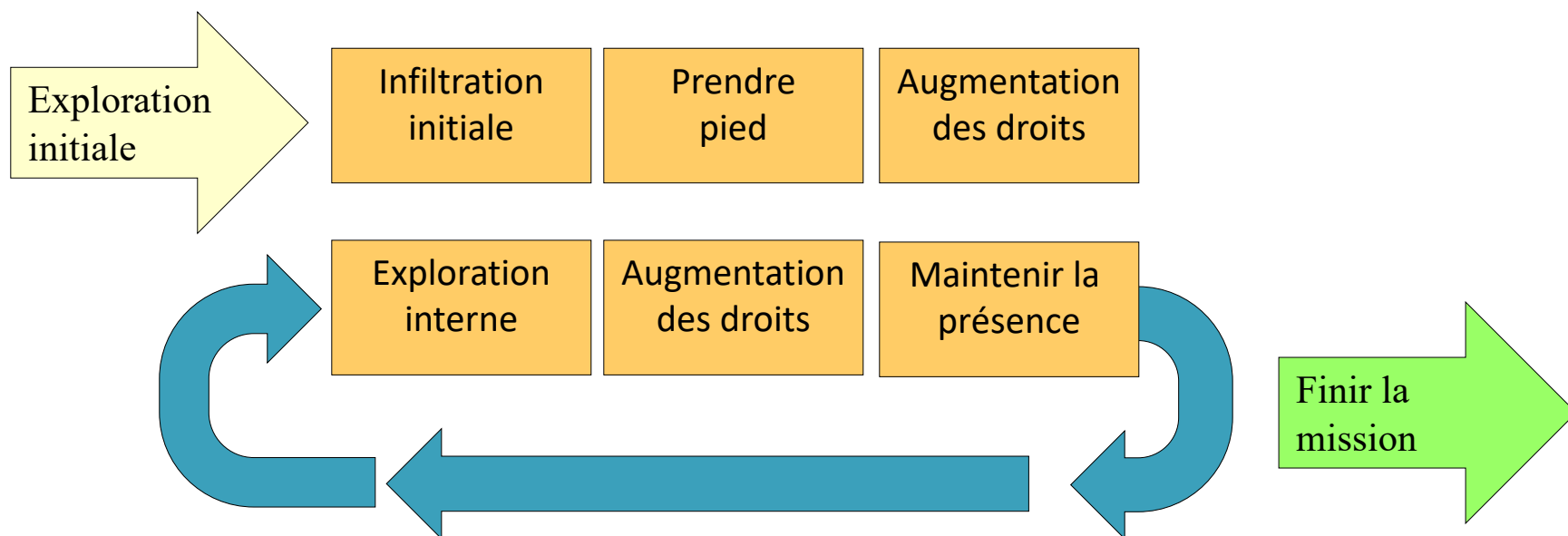
Menace persistante avancée (APT)

Menace persistante avancée (APT) – Un adversaire qui possède des niveaux élevés d'expertise sophistiquée et une quantité significative de ressources lui permettant d'atteindre ses objectifs en utilisant des vecteurs d'attaque multiples (ex. cyber, physique et frauduleuse)



Image Réf: Mr Mike Shinn, USNRC

Cycle de vie d'une menace persistante avancée



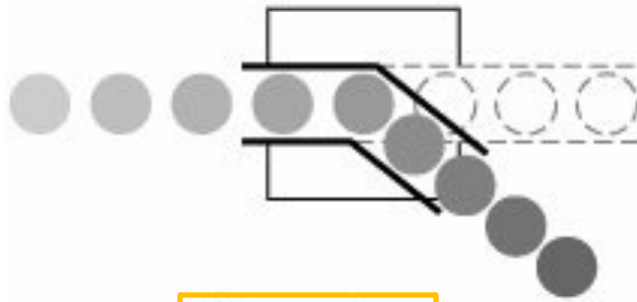
Le cycle de vie d'une menace persistante avancée

Activités potentielles post-infiltration

Créer/modifier/supprimer/exécuter des logiciels
Téléchargement de fichiers
Créer/supprimer des dossiers
Lister/démarrer/arrêter des processus/services
Modifier le registre
Capturer l'écran du bureau de l'utilisateur

Capturer les touches de clavier
Capturer les mouvements de la souris
Démarrer une commande interactive
Mettre en place un accès à distance (ex: graphique)
Récouter des mots de passe
Énumérer les utilisateurs
Énumérer les systèmes présents sur le réseau local
Mettre au repos durant un laps de temps défini
Déconnecter l'utilisateur de sa session
Arrêter le système

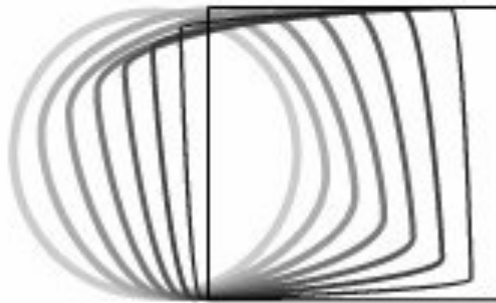
Types de Menace (d'Attaque)



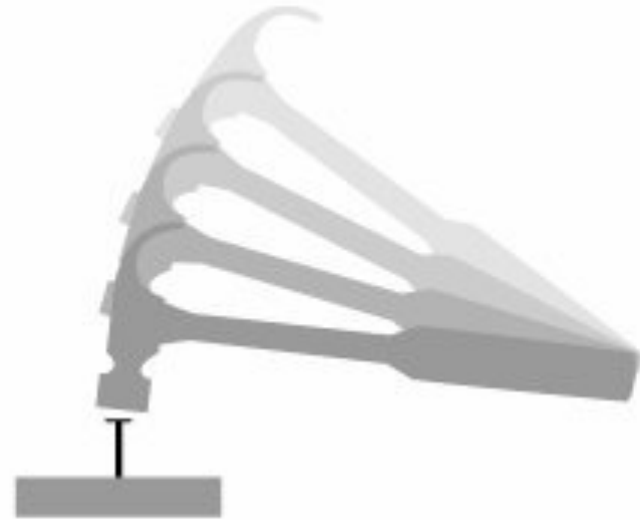
Interception



Interruption

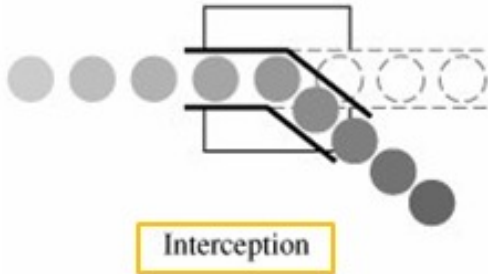


Modification



Fabrication

Types de Menace (d'Attaque)

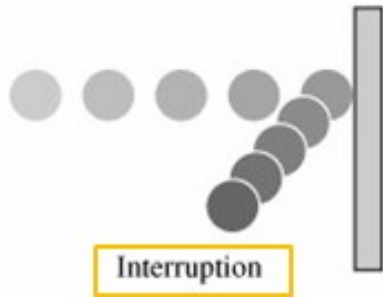


«Agent» non-autorisé gagne accès à l'information!

Exemples

- Vol propriété intellectuelle
- Vol des clefs de session

Types de Menace (d'Attaque)

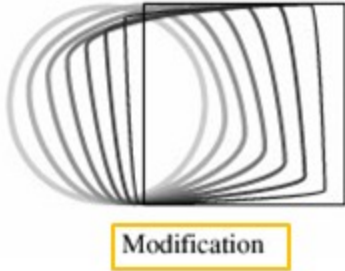


«Actifs» du système pas utilisable

Exemples

- DoS, DDoS

Types de Menace (d'Attaque)

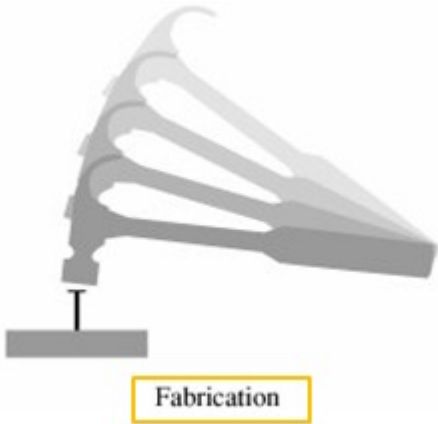


«Agent» non-autorisé arrive à modifier information!

Exemples

- Changer la valeur d'une transaction bancaire

Types de Menace (d'Attaque)



«Agent» non-autorisé arrive a créer de l'information!

Exemples

- Initier une nouvelle session de transfert après vol d'information

Menaces/Attaques réseaux (exemples)

Déni de service (DOS)/Perte de fonctionnalité

Bloque la capacité d'un opérateur d'observer et/ou répondre à des changements de conditions du système, surcharge le système jusqu'à le rendre inutilisable

Surveillance de systèmes cachée & Collection de données

Accès non-autorisé et enregistrement de données
Interception de messages (information)

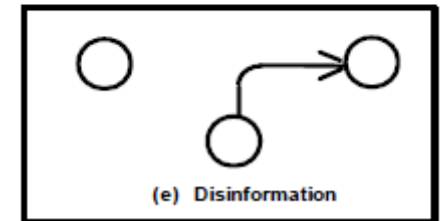
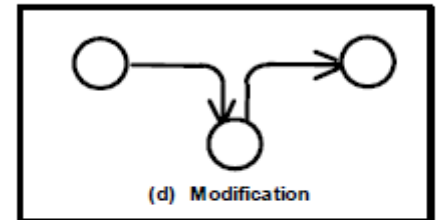
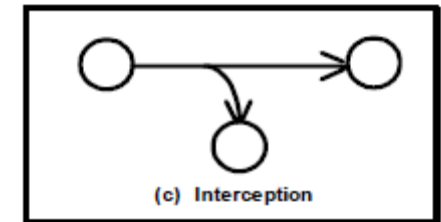
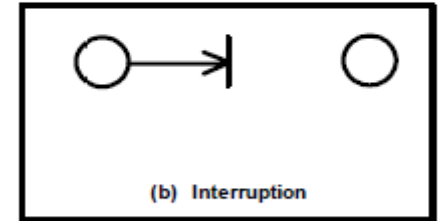
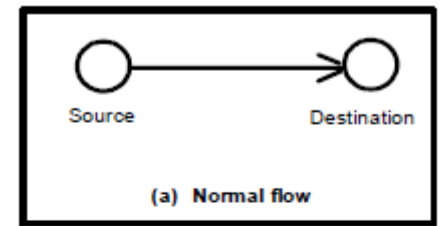
Interception (« Man in the Middle »)

Interception et modification de flux de données entre deux nœuds d'un même réseau

Usurpation d'opérateur menant à une action incorrecte

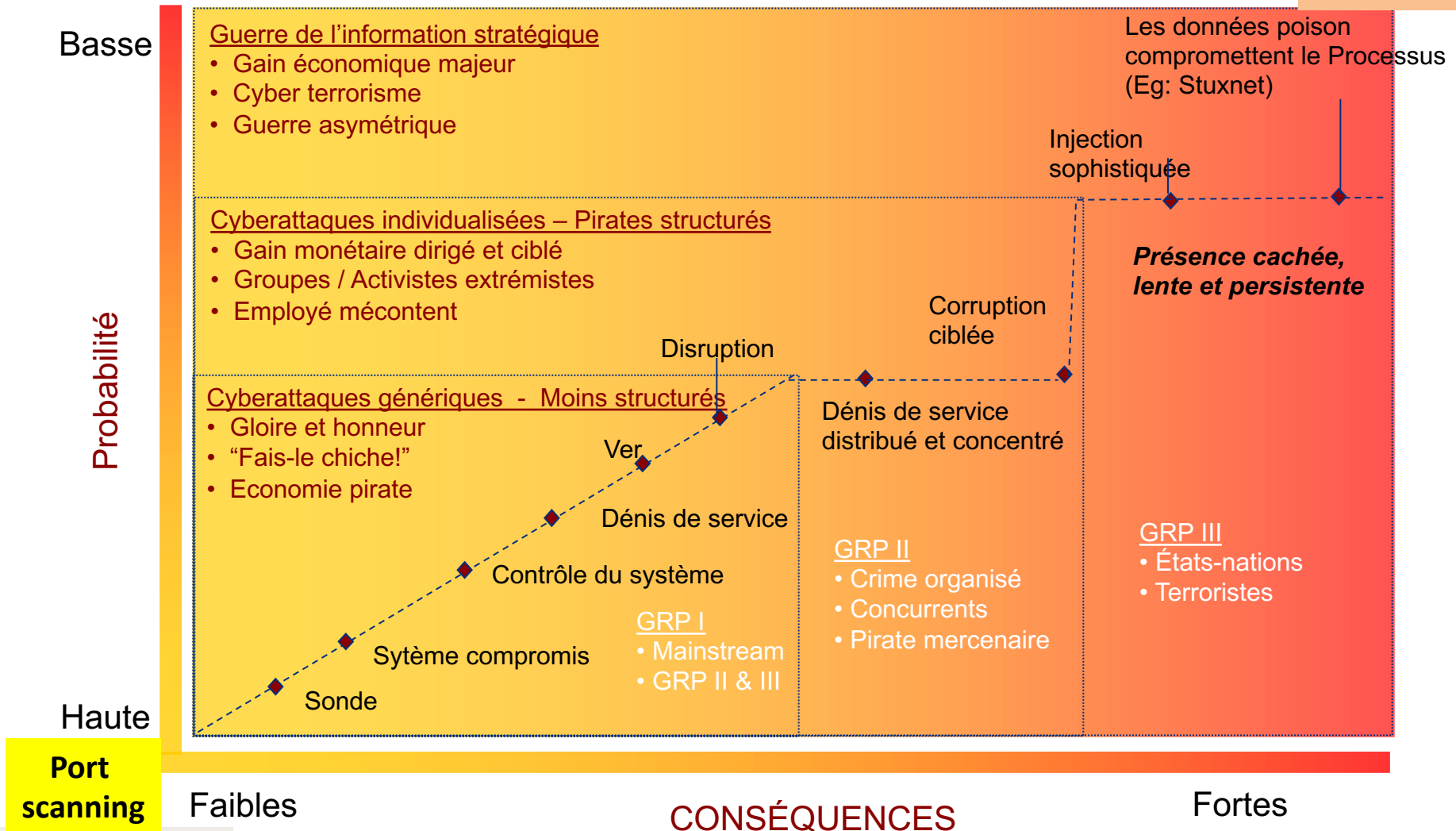
Force l'opérateur à prendre une mauvaise décision.

Manipulation directe de l'ordinateur/système de contrôle



Caractéristiques des menaces et attaques

Stuxnet



Attaques???

Attaques

- **Action destinée a porter atteinte a un aspect du SI**
 - **Concrétisation d'une menace**
 - **Nécessite l'exploitation d'une vulnérabilité**

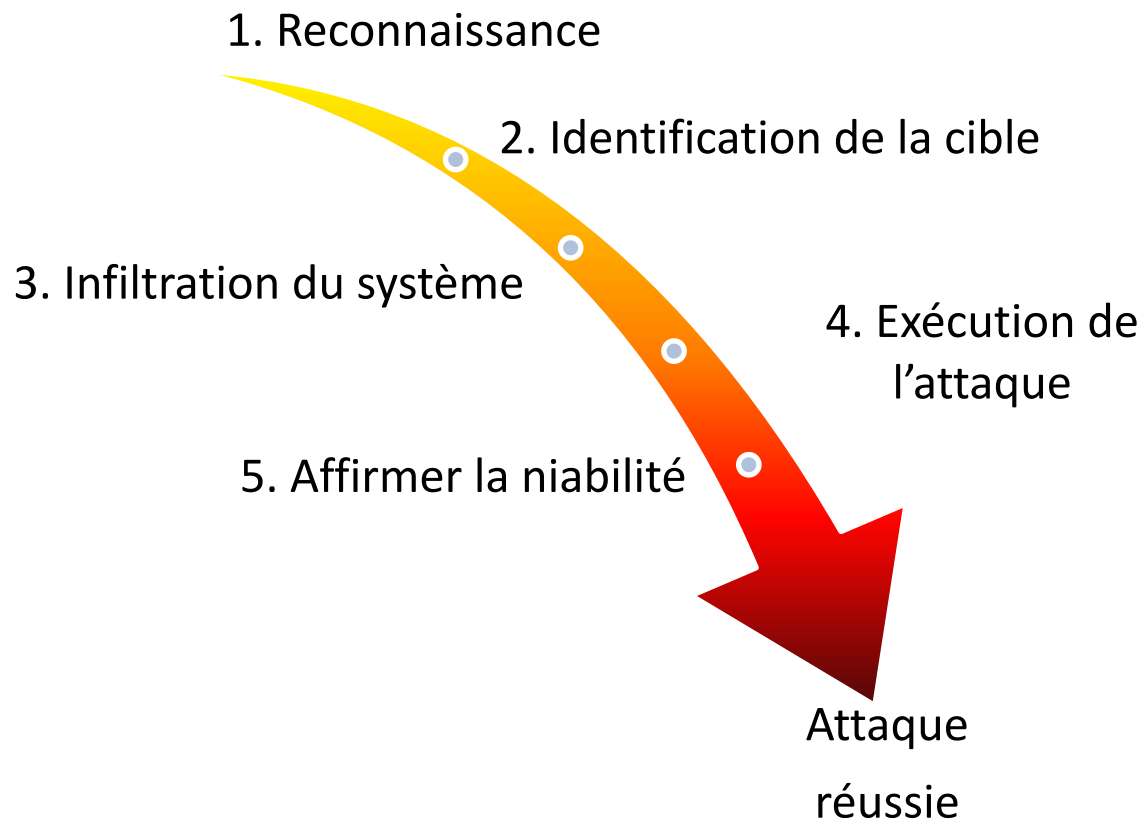
Tactiques et phases d'attaque

Les multiples vecteurs de menaces

MALWARE
WORM
SPAM
TROJAN HORSE
VIRUS
SPYWARE
PHISHING

Anatomie d'une attaque

Une attaque bien orchestrée consiste en quelques étapes:



Phase 1: Reconnaissance

Le but est de **collecter des informations sur la cible, les utilisateurs, et les processus dont peuvent être tirées des vulnérabilités.**

Croquis des points faibles d'un système

- Organisation, personnes, places,
- Procédures
- Systèmes

Collecte d'informations:

- Quelle(s) information(s) peu(ven)t être une cible facile?
- **Qui pourrait détenir ce(s)tte information(s) dans l'organisation?**
- Quels sont les matériels et les mesures de sécurités en place?
- Quel serait le moment le plus judicieux pour commencer l'attaque?
- Où l'information est-elle contenue et quels sont les points d'accès?



Techniques de collection d'informations

Sources d'information (comment obtenir l'information):

- Renseignements en source libre (OSINT) sur Internet
- **Vol d'ordinateurs et de fichiers**
- « **Ingénierie sociale** » (hameçonnage, harponnage, chasse à la baleine)
- Informant(s)
- **Espionnage** d'entrée de mots de passe et codes d'accès (manuel, par surveillance audio, ou vidéo)
- Espionnage sans fil
- **Fouille de poubelles**



Courriel et fuite d'information

Parfois l'information n'est pas aussi sûre qu'on le pense!

Les fuites peuvent contenir des informations sollicitées (ingénierie sociale) et non-sollicitées.

D'où vient l'information dans une organisation?



Last Updated: Tuesday, 15 June, 2004, 13:05 GMT 14:05 UK

 E-mail this to a friend  Printable version

Company secrets leak via e-mail

Confidential information is leaking out of companies due to careless e-mail use, a survey has found.



Nearly 40% of workers have received confidential information that was not meant for them according to a poll conducted by e-mail filtering firm SurfControl.

Sending an e-mail by mistake is easily done

Another 15% admit sending confidential information by mistake and 17% of those are unable to retrieve the data.

Few companies are protecting their sensitive data said SurfControl.

Alarm bells

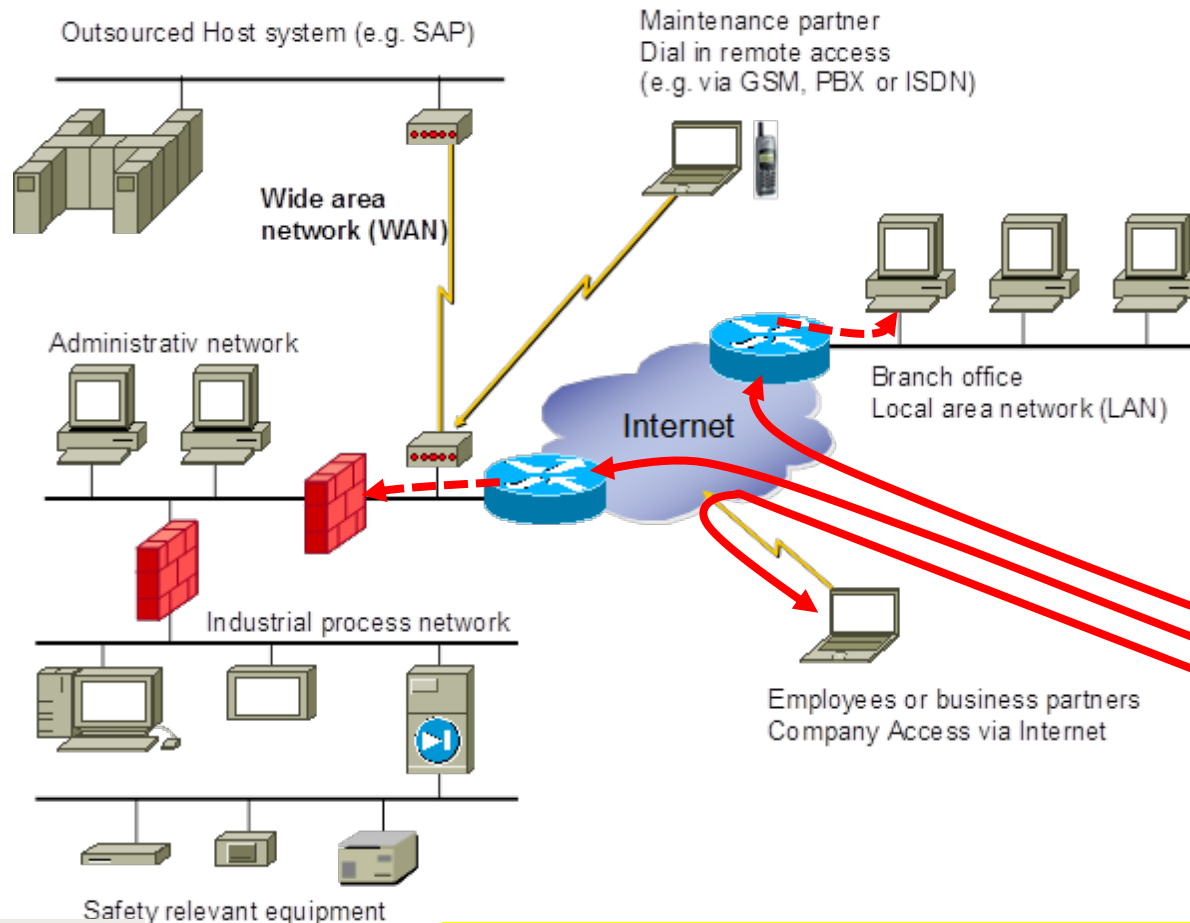
"Between 70 - 90% of company information is stored in electronic format and around 35% of this is held in the e-mail system," Martino Corbelli, the director of marketing at SurfControl, told BBC News Online.

Over 90% of respondents said they use e-mail to send and receive confidential information.

"Alarm bells should be ringing but I'm not sure they are," he said.

Phase 2: Identification de la cible

Les pirates explorent l'environnement technique et opérationnel



Ciblage initial

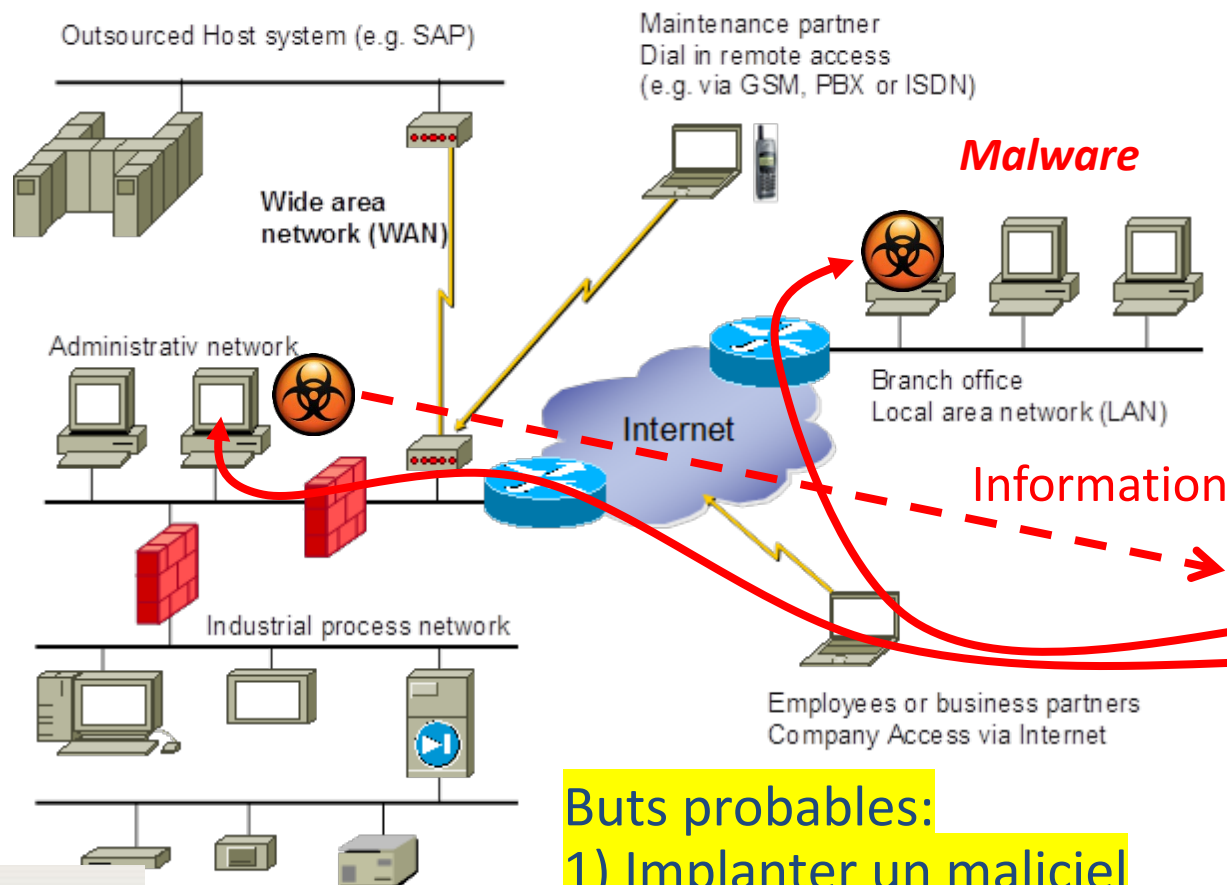
- Attaque d'ingénierie sociale contre des individus
 - Courriel, réseaux sociaux
 - Conversations directes
 - Collection d'informations dans le domaine public (**Google!**)
- Exploration active des failles de sécurité:
 - Connectivité réseaux ouverte (scanning!)
 - Composants logiciels obsolètes (version of applications!)
 - Services réseaux vulnérables (**CVE**)

Vecteurs d'attaque potentiels

- Les attaques d'**hameçonnages** peuvent être utilisées pour introduire des maliciels ou rediriger les utilisateurs vers des sites malicieux.
- Les **connexions réseaux non-sécurisées** incluant des réseaux sans-fil non-sécurisés peuvent être utilisées à la fois comme outil et comme base pour lancer certaines attaques.
- Les **périphériques amovibles**, telles les clés USB, peuvent facilement introduire des maliciels à l'intérieur d'un système informatique.
- Les **terminaux mobiles** (ex., smartphones et tablettes) peuvent être utilisés à la fois comme outil et comme base pour lancer certaines attaques ou pour la collection d'informations personnelles.
- Les **composants de navigation** peuvent être utilisés par une menace pour être en mesure de lancer une attaque en passant probablement par des sites malveillants.

Phase 3: Infiltration des systèmes informatiques

Les attaques réussissent grâce aux vulnérabilités et en établissant une présence au sein du réseau



Buts probables:

- 1) Implanter un maliciel
- 2) Continuer l'exploration

Toutes les cibles ont des failles

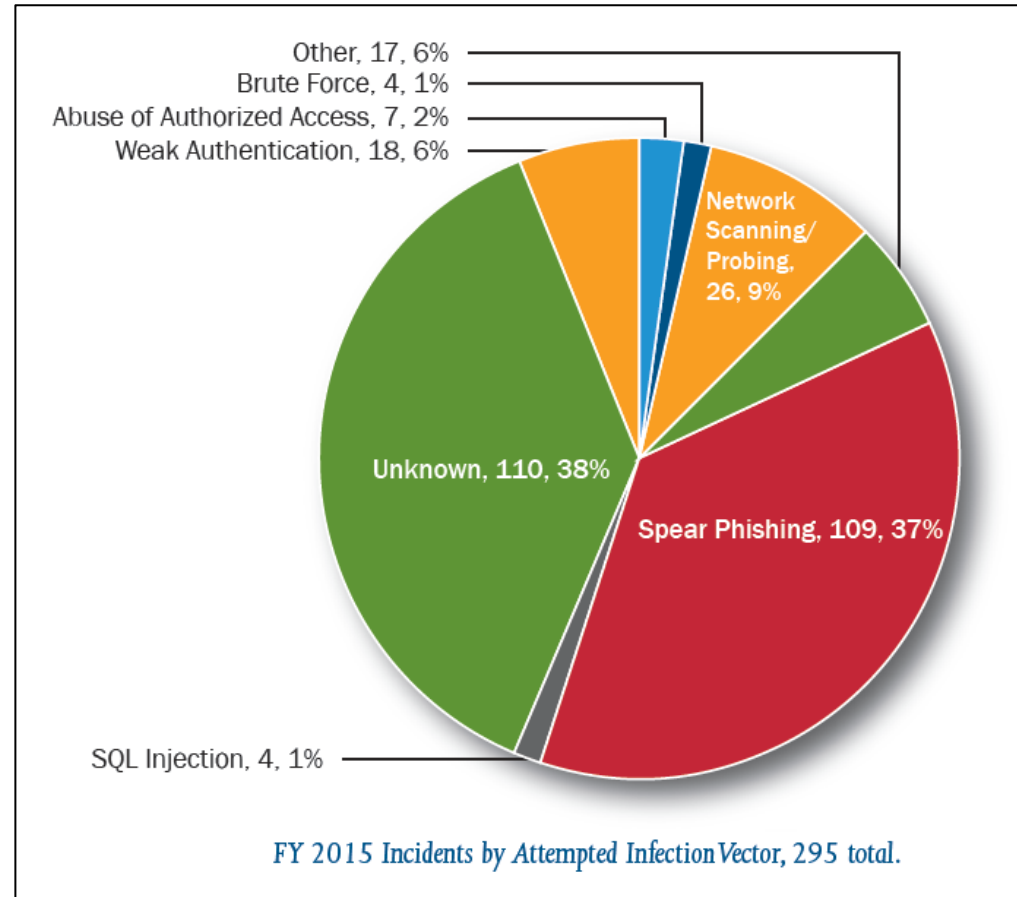
- Aucune cible n'est exempte de vulnérabilités, incluant celles résultant de:
 - Défaillances technologiques
 - Erreurs d'installation
 - Un abus de confiance d'un composant humain
- En général, plus la complexité d'un système augmente, et plus la probabilité de la présence de vulnérabilités augmente.



Vecteurs d'infection

ICS-CERT a recensé plus de 295 incidents mettant en cause des infrastructures critiques(CI) aux Etats Unis (10/2014 - 9/2015)

“Unknown” – Pas de données scientifiques suffisantes pour identifier le vecteur d'intrusion initial



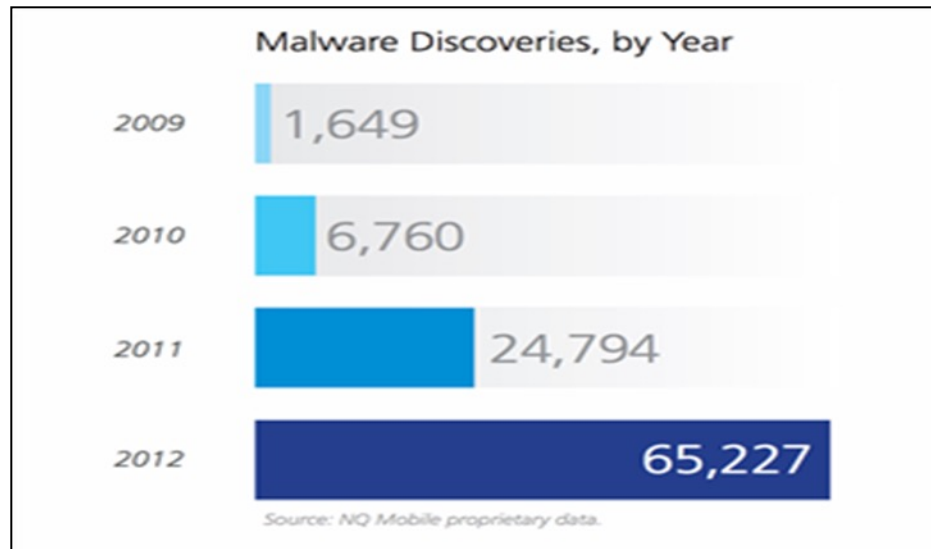
Cible Mobile – Tablettes / Smartphones

Logiciels contrefaits et infectés (Dec 2012)

La quantité de maliciels à destination des terminaux mobiles équipés d'Android a plus que doublé en un an, d'après un récent rapport d'une société de sécurité mobile.

Le nombre de maliciels pour la plateforme Android est passé de 25000 en 2011 à plus de 65000 en 2012.

Le rapport annuel, publié par la société de sécurité mobile NQ Mobile, a aussi estimé que 33 millions de terminaux Android ont été infectés en 2012, ayant augmenté de presque 11 millions en un an — une augmentation de plus 200 pourcent.



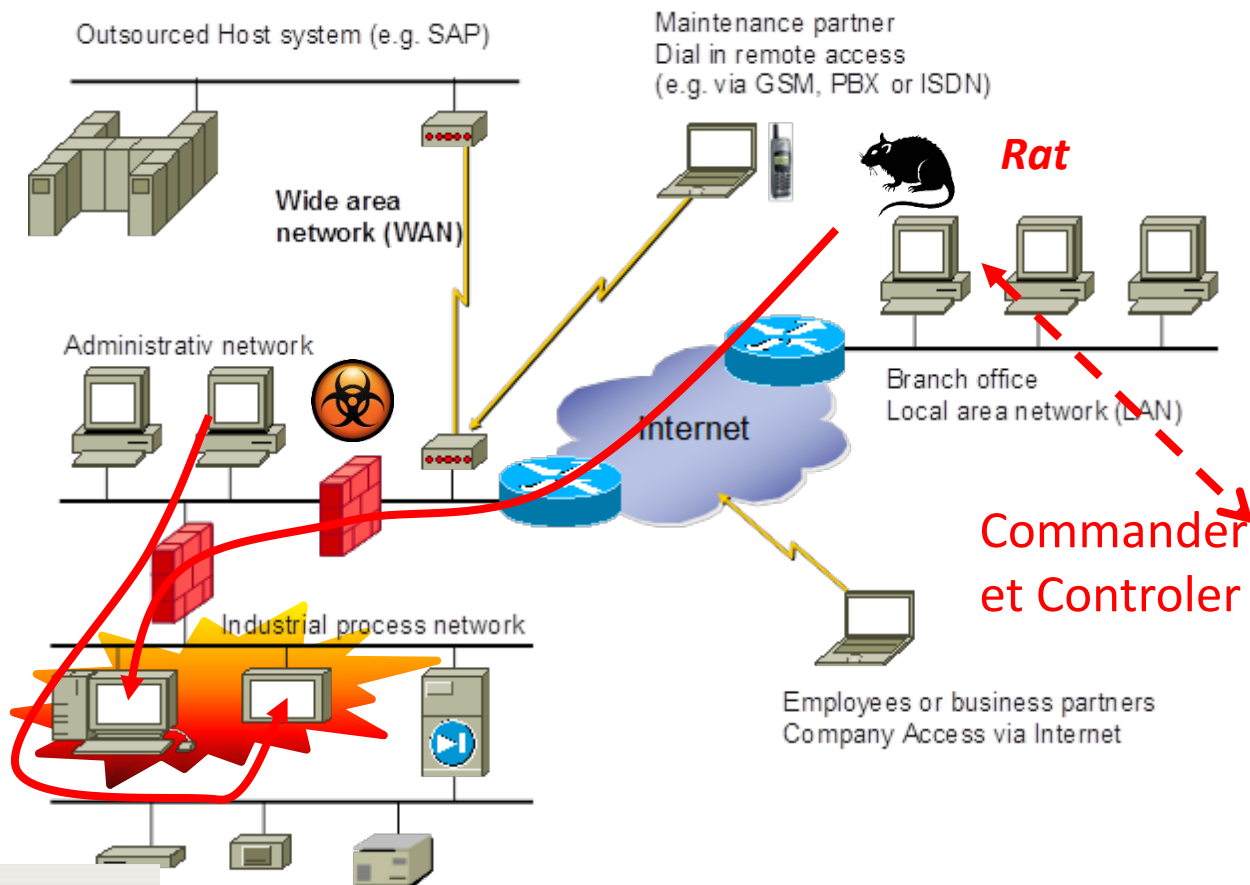
Les technologies facilitent les infiltrations

ACCÈS = INFILTRATION POSSIBLE



Phase 4: Exécution de l'attaque

Les pirates peuvent également utiliser des connectiques externes pour insérer plus de failles à exploiter et exporter des informations



Caractéristiques des attaques

L'attaque en soi

- Peut avoir un **impact immédiat** causant des dégâts ou une dégradation notoire de la fonction ou de l'équipement
- Peut être **continue** afin de collecter secrètement des informations
- Peut être **retardée ou déclenchée à volonté**
- Peut être **synchronisée avec d'autres activités** qui peuvent inclure des actions physiques (attaque hybride)

Vecteur d'attaques hybrides

Les attaques hybrides sont constituées d'une partie de cyberattaque(s) et d'attaques physiques associées. On peut citer le cas d'une attaque physique sur un système de contrôle d'accès pour permettre l'entrée sur le site de personnes non-autorisées

Cybercomposant

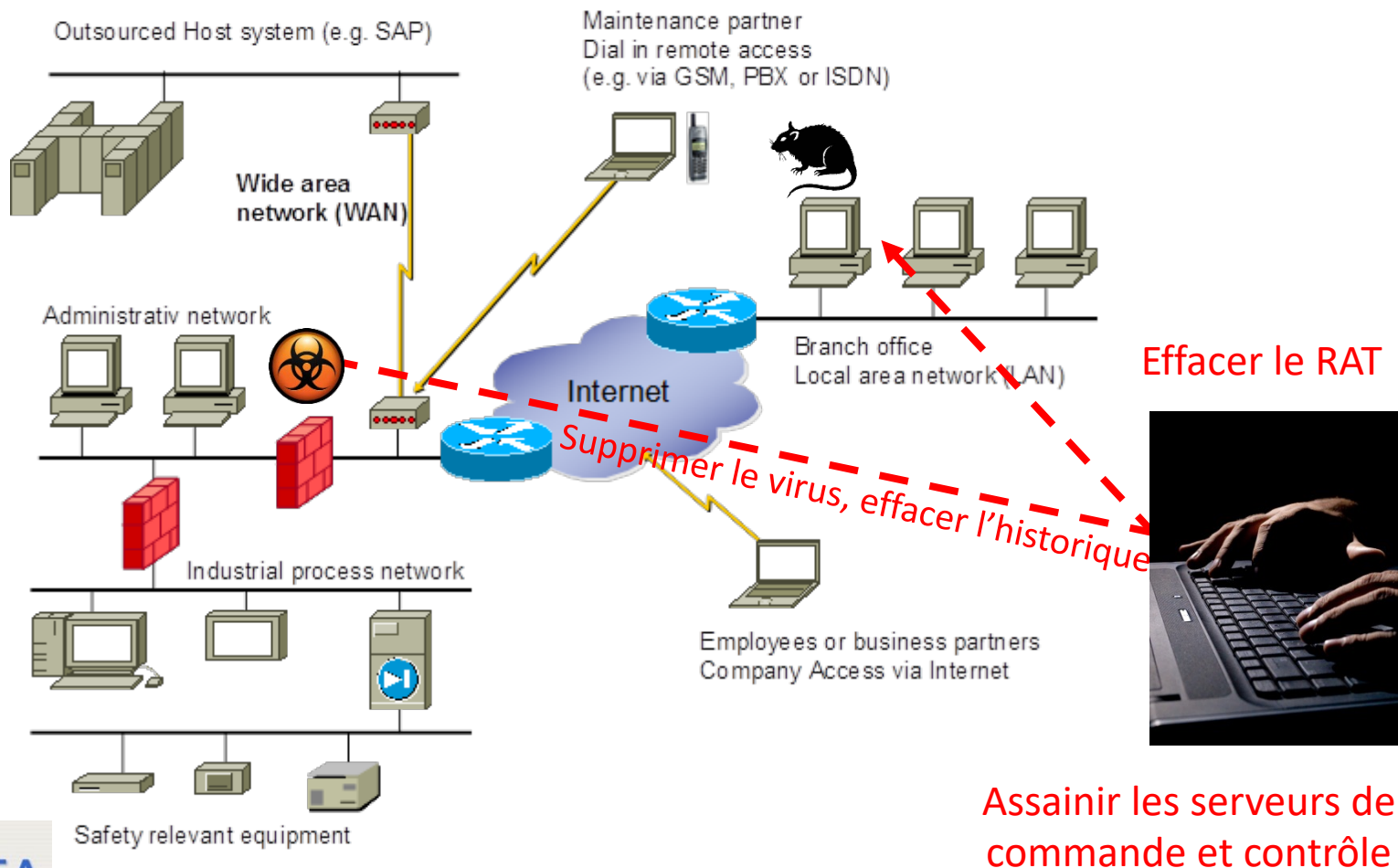
- Lancer une attaque de déni de service sur le réseau de communication de la centrale
- Injecter de fausses images vidéos dans le flux de circuit fermé
- Créer une distraction en infiltrant le système de suppression des flammes du bâtiment
- Entrer des données contrefaites dans le système de contrôle d'accès de la centrale

Composant physique

- Explosifs placés dans la centrale
- Contrôle d'accès sous contrôle de l'adversaire
- Une section d'assaut s'introduit dans une zone contrôlée

Phase 5: Assurer le déni plausible

Les pirates peuvent tenter de cacher/effacer leur traces



Assurer le déni plausible

Le pirate informatique peut tenter de masquer l'incident

- Reste non-détecté
- Couvre les traces
- Garde une porte ouverte pour un accès futur

Cela peut être réalisé en:

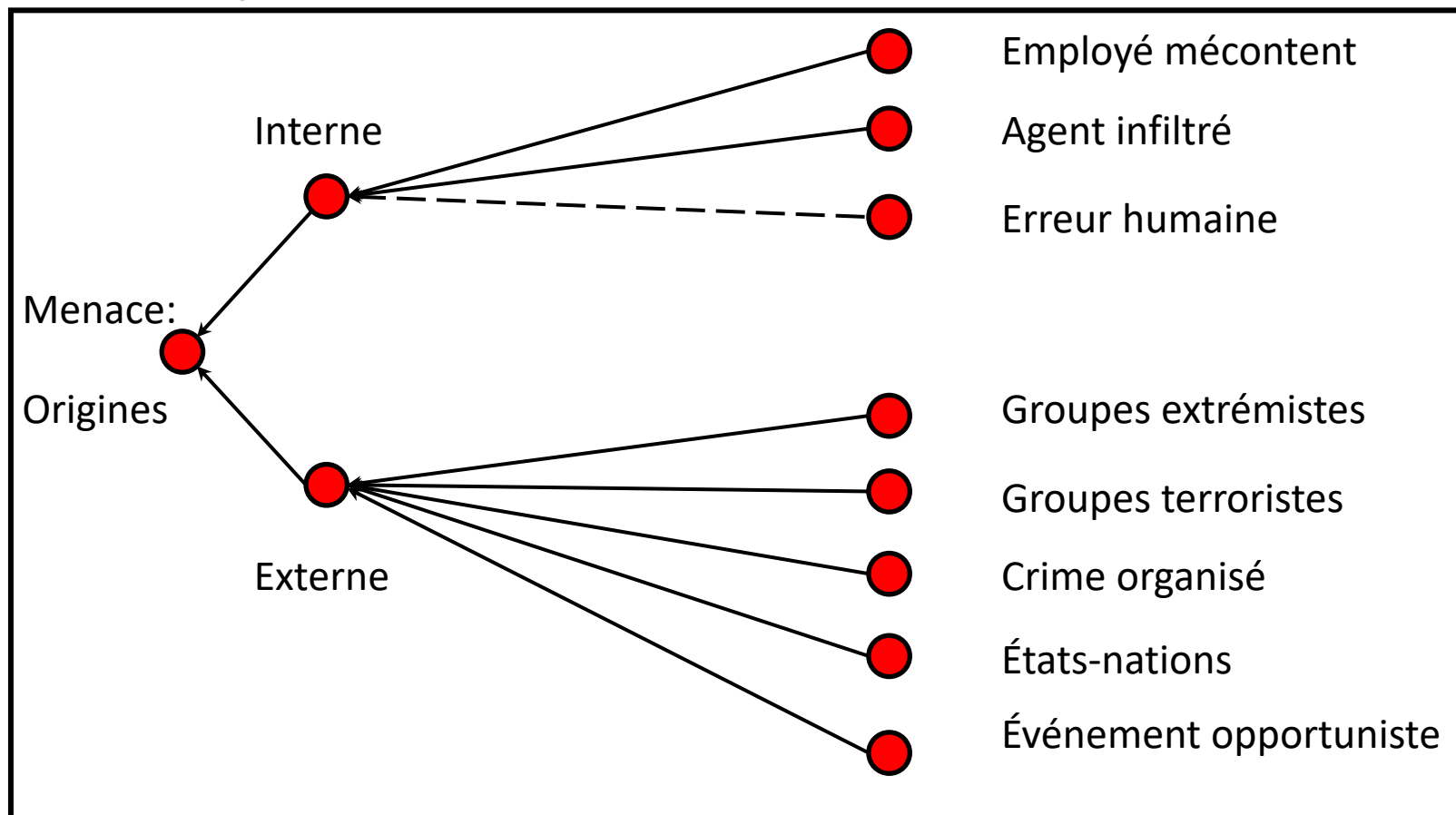
- **Modifiant les historiques** des systèmes locaux et/ou
- **Restituant les logiciels manipulés** à leur état et configuration initiale
- **Manipulant à distance pour arrêter le fonctionnement** ou assurer l'auto-destruction ou l'auto-suppression.
- **Endommageant physiquement** le système pour détruire les traces (E.g: pirate causes power outage to stop machine)

Attaques

Qui nous attaque ???

Attaques

Qui nous attaque ???

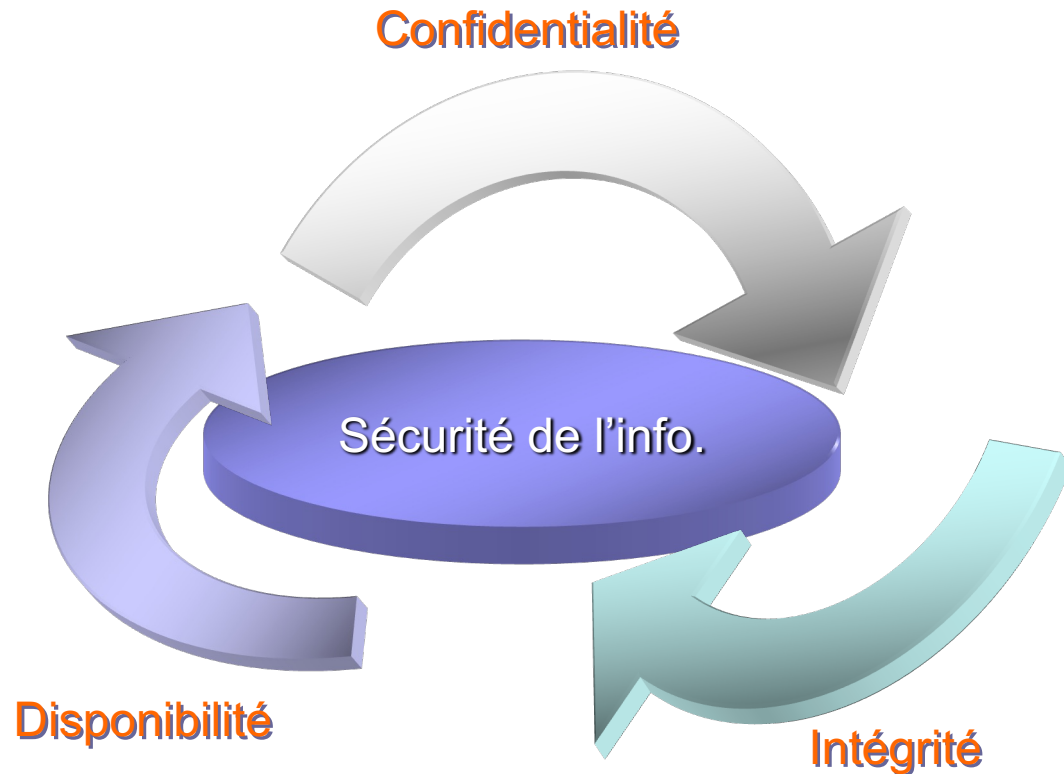


Principes de Sécurité

Principes de la sécurité de l'information

La sécurité de l'information repose sur l'importance des aspects suivants :

Confidentialité
Intégrité
Disponibilité



Confidentialité

***La confidentialité est le maintien du secret des informations »
(Le Petit Robert)***

- Dans le cadre d'un système d'information, cela peut être vu comme une protection des données contre une divulgation non autorisée
- Assurer que seuls les « agents » autorisés ont accès a « l'objet » a protéger
 - Accès= {voir, lire, entendre, imprimer...ou simplement être au courant de l'existence!}
- 2 actions complémentaires permettant d'assurer la confidentialité des données
 - Limiter leur accès par un mécanisme de contrôle d'accès
 - Transformer les données par des procédures de chiffrement

Intégrité

- L'intégrité permet de certifier que les données, les traitements ou les services n'ont pas été modifiés, altérés ou détruits tant de façon intentionnelle ou accidentelle pendant
 - Le traitement
 - La transmission
 - La conservation
- L'altération est principalement occasionnée par le média de transmission mais peut provenir du système d'informations
- L'intégrité comprend 3 éléments:
 - L'intégralité
 - La précision/L'exactitude
 - La validité

Disponibilité

- **Assurer** que les « assettes » sont disponibles aux « agents » autorisés au **moment approprié**.
- La disponibilité est de pair avec son accessibilité
 - Une ressource doit être accessible, avec un temps de réponse acceptable
- Un service doit aussi être assuré avec le minimum d'interruption en respect avec l'engagement établi

La preuve

- La preuve permet de garantir la traçabilité des accès et des tentatives d'accès et la conservation de ces traces comme preuves exploitables
- Forensic Numérique

Identification et Authentification

- L'**identification** est le moyen « d'identifier » un «agent» (username)
- L'**authentification** est le processus de prouver que « l'agent » est bien celui qu'il prétend être (un mot de passe)
- Ces mesures doivent être mises en place afin d'assurer
 - La confidentialité et l'intégrité des données d'une personne
 - La non répudiation, c'est à dire qu'une personne identifiée et authentifiée ne peut nier une action
- L'identification peut être vu comme un simple login de connexion sur un système

Contrôles de sécurité informatique

Prévention, Détection, Action

Concepts clés:

- Approche graduée
- Défense en profondeur
- Besoin de savoir
- Contrôle de l' accès
- Authentification
- Autorisation

Types de contrôles:

- Administratif
- Physique
- Technique



Prochainement

Human in the loop!